Sistema del Comedor de la UPTAG

Informe Auditor

Gobierno Bolivariano de Venezuela
Ministerio del Poder Popular para Educación Universitaria, Ciencia y Tecnología

UPTAG
UNIVERSIDAD POLITÉCNICA TERRITORIAL DE FALCÓN ALONSO GAMERO
PNF Informática

REPÚBLICA BOLIVARIANA DE VENEZUELA
MINISTERIO DEL PODER POPULAR PARA LA EDUCACIÓN UNIVERSITARIA
SANTA ANA DE CORO – ESTADO FALCÓN
UNIVERSIDAD POLITÉCNICA TERRITORIAL DE FALCÓN ALONSO GAMERO



Informe Técnico de Auditoría

Sistema De Gestión Administrativa del Comedor de la

“Universidad Politécnica Territorial de Falcón Alonso Gamero”

Versión del documento	Fecha	Emisión
1.2	11/03/2026	Documento confidencial

Equipo auditor			
Joseph Perez	Nikol Garcia	Josue Centeno	Katherine Hernandez
25.945.549	29.900.573	30.354.180	26.656.307

Asesores técnicos
Ing. Joel Medina

TABLA DE CONTENIDO

RESUMEN 4

RESUMEN TECNICO 5

MARCO DE REFERENCIA 6

MATRIZ DE RIESGO 6

OWASP TOP 10 2025 7

Hallazgos de Severidad Crítica 8

Configuración Insegura de Privilegios en el Motor de Base de Datos. 9

Hallazgos de Severidad Alta 10

Bloqueo Lógico Irreversible de la Cuenta Administrativa (Denegación de Servicio Autoinfligida) 11

Denegación de Servicio (DoS) por Agotamiento de Recursos de Conexión 13

EXPOSICIÓN DE IDENTIFICADORES DE SESIÓN POR AUSENCIA DE ATRIBUTOS DE SEGURIDAD (HTTPONLY Y SECURE). 14

Denegación de Servicio por Inconsistencia en Nomenclatura y Exposición de Rutas Críticas 15

Ruptura de Enrutamiento y Omisión de Recursos en el Módulo Operador encargado de la Gestión Estudiantil (Error HTTP 404) 16

Hallazgos de Severidad Media 18

Registro De Usuarios Abierto Y Exceso De Privilegios 19

Deficiencias en la Experiencia de Usuario (UX) y falta de Adaptabilidad 20

Fallo Lógico de Validación de Credenciales en la Actualización del Perfil de Usuario 21

Inconsistencia Arquitectónica y Omisión Documental en Controles de Acceso (Tabla No Declarada) 23

AUSENCIA DE CABECERAS DE SEGURIDAD HTTP (SECURITY HEADERS) EN EL SERVIDOR WEB. 25

Deficiencias en el enrutamiento de navegación y persistencia de enlaces rotos. 27

Gestión inadecuada de la finalización de sesión y redirección anómala. 28

AUSENCIA DE CREDENCIALES DE INICIALIZACIÓN Y DEFICIENCIAS EN LA DOCUMENTACIÓN PROCEDIMENTAL. 29

Análisis de Seguridad con Herramientas Automatizadas 31

Análisis Dinámico de Aplicaciones (DAST) - OWASP ZAP 32

Análisis Estático de Seguridad (SAST) – SonarQube 33

Inspeccion de codigo.....34

Arquitectura de Software Desordenada y Baja Escalabilidad.....35

Documentación Técnica Insuficiente y Omisión de Comentarios en Funciones Críticas.....36

Deficiencia en la Trazabilidad y Gestión del Control de Versiones.....37

Prueba de Rendimiento.....38

Observaciones finales.....40

Visión General de la Auditoría.....41

- **Seguridad y Resiliencia**.....41
- **Documentación Técnica y de Usuario**.....41
- **Análisis del Código Fuente**.....41
- **Gestión del Control de Versiones**.....41
- **Divergencia Crítica frente a los Requerimientos de la Comunidad**.....41
- **Ausencia Documental de Metodologías**.....42
- **Cumplimiento Legal y Licenciamiento**.....42
- **Ayuda Contextual y Tooltips en la Interfaz de Usuario**.....42
- **Carencia Absoluta de un Entorno de Pruebas en el Desarrollo**.....43

Conclusiones.....44

RESUMEN

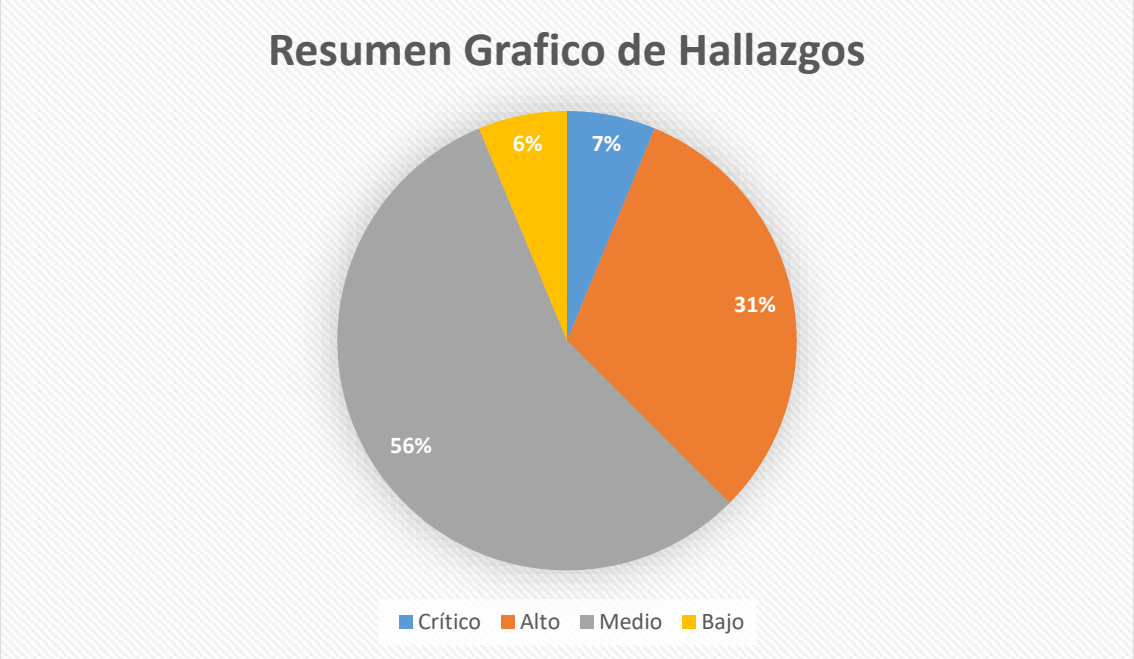
El presente informe técnico expone los resultados de la auditoría de software realizada al Sistema de Gestión Administrativa del Comedor de la Universidad Politécnica Territorial Alonso Gamero (UPTAG). La evaluación se fundamentó en la ejecución de pruebas unitarias, de integración y de seguridad dinámica (DAST), orientadas a determinar la calidad y resiliencia de la plataforma.

Como resultado del análisis, se identificaron diversas debilidades estructurales que afectan la integridad de los datos y la continuidad operativa. Entre los hallazgos destacan: brechas de seguridad por falta de sanitización en los puntos de entrada (inputs), fallos de configuración en el lado del servidor manifestados en errores de respuesta 500 (Internal Server Error) debido a rutas de navegación mal gestionadas y deficiencias en el manejo de excepciones que exponen información técnica sensible.

Cada vulnerabilidad ha sido categorizada según su nivel de riesgo, acompañada de una descripción técnica detallada y una propuesta de mitigación. Este documento tiene como objetivo final servir de hoja de ruta para la optimización y el fortalecimiento del sistema, garantizando un entorno digital seguro y eficiente para la comunidad universitaria.

RESUMEN TECNICO

Nivel de Riesgo	Cantidad de Hallazgos	Descripción General
Crítico	**1**	Configuración insegura de privilegios en la base de datos.
Alto	**5**	Fallos de autenticación, denegación de servicio (DoS) y exposición de sesiones.
Medio	**9**	Deficiencias en UX, lógica de perfiles, falta de cabeceras de seguridad, enlaces rotos y documentación.
Bajo	**1**	Optimización de interfaz y rendimiento (Performance 81/100).
Total	**16**	



MARCO DE REFERENCIA

MATRIZ DE RIESGO

Nivel de Riesgo	Descripción del Hallazgo
Crítico	Amenaza directa a la continuidad del servicio y la seguridad de los datos. Explotación inminente.
Alto	Riesgo significativo de acceso no autorizado o corrupción de procesos administrativos.
Medio	Vulnerabilidad explotable bajo escenarios específicos; compromiso parcial de la integridad.
Bajo	Anomalía funcional o cosmética con impacto mínimo en la seguridad del núcleo del sistema.

Esta escala de priorización se basa en el estándar CVSS v4.0 (Common Vulnerability Scoring System), se utilizó esta versión ya que, es más precisa que la v3.1 porque separa mejor los factores técnicos de los operativos.

OWASP TOP 10 2025

- **A01:2025** - Control de acceso roto
- **A02:2025** - Mala configuración de seguridad
- **A03:2025** - Fallas en la cadena de suministro de software
- **A04:2025** - Fallos criptográficos
- **A05:2025** - Inyección
- **A06:2025** - Diseño inseguro
- **A07:2025** - Fallos de autenticación
- **A08:2025** - Fallas de integridad de software o datos
- **A09:2025** - Fallas en el registro y alerta de seguridad
- **A10:2025** - Mal manejo de condiciones excepcionales



HALLAZGOS DE SEVERIDAD CRÍTICA

CONFIGURACIÓN INSEGURA DE PRIVILEGIOS EN EL MOTOR DE BASE DE DATOS.

Riesgo: Critico/ 9.3

Categoría: OWASP: A02:2025 - Mala configuración de seguridad

Modulo: Conexión a la Base de Datos (Código)

Descripción: Se ha identificado que la aplicación utiliza credenciales de base de datos con privilegios excesivos o perfiles predeterminados para su operación habitual. Esta práctica contraviene el Principio de Menor Privilegio (PoLP).

Causa: El uso de credenciales administrativas o perfiles predeterminados en el archivo de conexión (db.php), sumado a la ausencia de una política de Mínimo Privilegio, permite el acceso total al motor de base de datos desde cualquier origen (host %).

Recomendaciones: Se recomienda fortalecer la seguridad de la base de datos mediante la creación de un usuario exclusivo con privilegios mínimos (SELECT, INSERT, UPDATE), eliminando permisos críticos de alteración de estructura o archivos. Asimismo, es imperativo aplicar una restricción de host para limitar el acceso únicamente a la IP del servidor web y asegurar el cifrado de credenciales en db.php utilizando contraseñas de alta entropía.

db.php !M

backend > connect > db.php > ...

```php
<?php
$servername = "localhost";
$username = "root";
$password = "";
$dbname = "comedor_uptag";

$conn = new mysqli($servername, $username, $password, $dbname);

if ($conn->connect_error) {
    die("Conexión fallida: " . $conn->connect_error);
}
?>
```



HALLAZGOS DE SEVERIDAD ALTA

BLOQUEO LÓGICO IRREVERSIBLE DE LA CUENTA ADMINISTRATIVA (DENEGACIÓN DE SERVICIO AUTOINFLIGIDA)

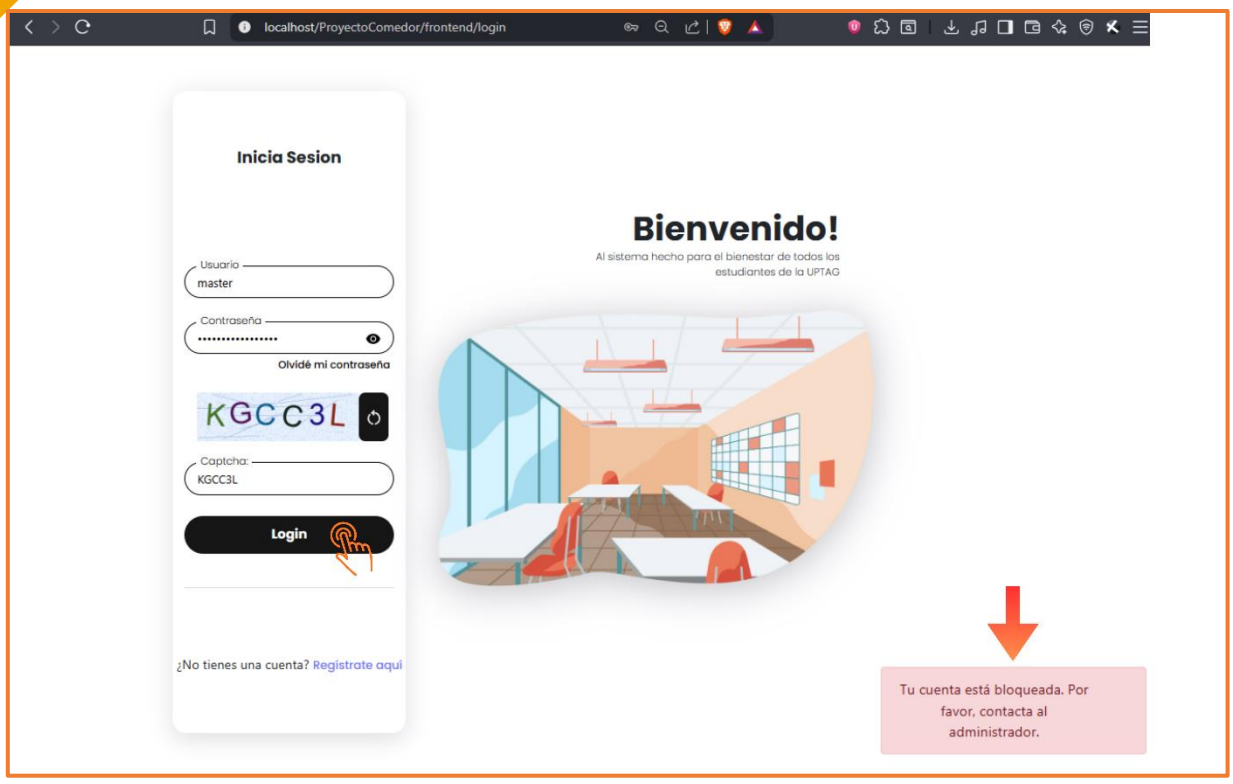
Riesgo: Alto / 8.9

OWASP: A06:2025 - Diseño inseguro / A07:2025 - Fallos de autenticación

Descripción: La auditoría a los mecanismos de protección contra fuerza bruta evidencia un fallo crítico de diseño en la lógica de recuperación de cuentas que deriva en un Deadlock (bloqueo circular) insalvable. El sistema inactivo automáticamente cualquier perfil tras tres intentos fallidos de acceso; sin embargo, al aplicar esta política restrictiva de forma indiscriminada al superusuario ("Master"), la interfaz solicita paradójicamente "contactar al administrador" para su restitución. Al ser esta la única cuenta con privilegios para gestionar accesos, su inhabilitación clausura total y permanentemente el módulo administrativo, permitiendo que un simple error humano o un ataque intencionado ejecute una Denegación de Servicio (DoS) a nivel gerencial sin vías de recuperación desde la interfaz de usuario.

Causa: Ausencia de un modelado de amenazas adecuado durante la fase de diseño de la arquitectura de autenticación. No se contemplaron casos de uso excepcionales, ni vías de recuperación alternativas para cuentas de máximo privilegio. El sistema carece de un mecanismo de "retardo exponencial" o bloqueo temporal, optando por un bloqueo absoluto que requiere intervención manual de un rol que acaba de ser inhabilitado.

Recomendaciones: Modificar la lógica del código fuente para que el bloqueo de la cuenta administrativa no sea definitivo. En su lugar, se debe implementar un bloqueo temporal basado en tiempo (por ejemplo, restricción de acceso por 15 minutos tras 3 intentos fallidos, escalando el tiempo si los fallos persisten), permitiendo que la cuenta recupere su operatividad automáticamente tras expirar el lapso de penalización. Otra solución sería desarrollar un flujo de recuperación de emergencia exclusivo para el rol "Master". Esto puede incluir el envío de un token criptográfico de un solo uso (OTP) al correo electrónico registrado del administrador o la utilización de las preguntas de seguridad ya contempladas en la base de datos, garantizando una vía técnica para restituir el acceso sin depender de un tercero inexistente.


localhost/ProyectoComedor/frontend/login
Inicia Sesion
Usuario
master
Contraseña
Olvidé mi contraseña
KGCC3L
Captcha:
KGCC3L
Login
¿No tienes una cuenta? Regístrate aquí
Bienvenido!
Al sistema hecho para el bienestar de todos los estudiantes de la UPTAG
Tu cuenta está bloqueada. Por favor, contacta al administrador.

DENEGACIÓN DE SERVICIO (DOS) POR AGOTAMIENTO DE RECURSOS DE CONEXIÓN

Riesgo: Alto / 8.7

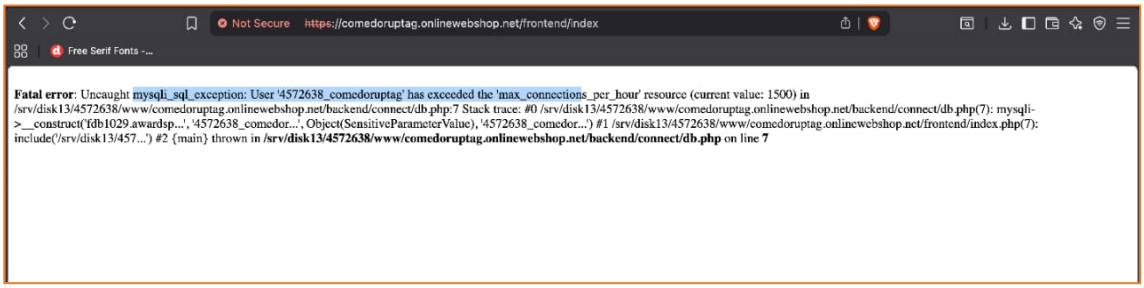
Categoría: OWASP: A10:2025 - Mal manejo de condiciones excepcionales / Fallo de Disponibilidad Operativa

Modulo: Conexión a la Base de Datos (db.php).

Descripción: Se ha confirmado una caída total del servicio tras ejecutar pruebas de seguridad con la herramienta SQLMap, lo que provocó que el usuario de la base de datos excediera el límite de recursos max_connections_per_hour (valor actual: 1500). Este incidente bloquea el acceso a todas las funciones del sistema, inhabilitando la operatividad del comedor. Simultáneamente, la aplicación arroja un Error Fatal que expone rutas físicas internas del servidor (ej. /srv/disk13/4572638/...), lo que facilita la fase de reconocimiento para ataques dirigidos

Causa: Gestión deficiente de la persistencia de datos y vulnerabilidad ante ráfagas de peticiones automáticas. El sistema no cierra las conexiones de forma explícita ($conn->close()) y carece de mecanismos de estrangulamiento (*throttling*) o balanceo de carga, permitiendo que herramientas de auditoría saturen el límite de conexiones del hosting en pocos minutos debido a la arquitectura "espagueti" del software.

Recomendaciones: Es imperativo implementar el cierre explícito de conexiones en todos los scripts del backend una vez finalizada la ejecución de las sentencias SQL para liberar recursos del motor de base de datos de manera inmediata. Además, configurar bloques try-catch en el archivo db.php para capturar excepciones de mysqli y redirigir a una página de error genérica, evitando la fuga de información técnica sensible.



EXPOSICIÓN DE IDENTIFICADORES DE SESIÓN POR AUSENCIA DE ATRIBUTOS DE SEGURIDAD (HTTPONLY Y SECURE).

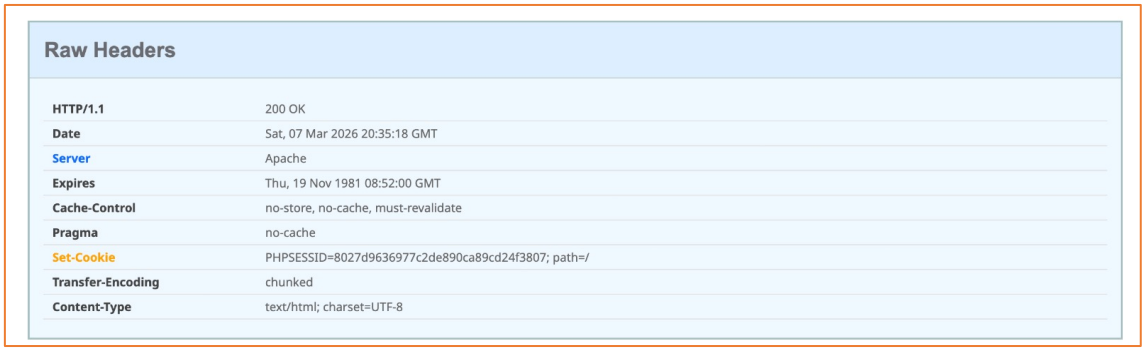
Riesgo: Alto / 7.5

Categoría: OWASP: A01:2021 - Pérdida de Control de Acceso

Descripción: Se determinó que las cookies de sesión del sistema carecen de las banderas de seguridad HttpOnly y Secure. Esta configuración deficiente permite que el identificador de sesión sea accesible mediante scripts de cliente (JavaScript) y sea transmitido a través de canales no cifrados (HTTP). Esta vulnerabilidad facilita el secuestro de sesiones activas mediante ataques de Cross-Site Scripting (XSS) o interceptación de tráfico en la red.

Causa: El servidor de aplicaciones y los scripts de conexión en el backend no definen explícitamente las directivas de protección en el encabezado Set-Cookie. El sistema ignora los estándares de endurecimiento (Hardening) de sesiones, permitiendo que datos sensibles de navegación queden expuestos en el DOM del navegador y en el tráfico de red en texto plano.

Recomendaciones: Para blindar la gestión de identidades, se recomienda configurar obligatoriamente el parámetro session.cookie_httponly = 1 y session.cookie_secure = 1 en el archivo de configuración php.ini o mediante la función session_set_cookie_params(). Adicionalmente, se debe asegurar que el manejo de rutas, como la captura del CSV, no concatene tokens de sesión en la URL (Method GET), evitando que la persistencia de la sesión dependa de rutas visibles que puedan ser almacenadas en el historial del navegador o logs del servidor.



DENEGACIÓN DE SERVICIO POR INCONSISTENCIA EN NOMENCLATURA Y EXPOSICIÓN DE RUTAS CRÍTICAS

Riesgo: Alto / 7.2

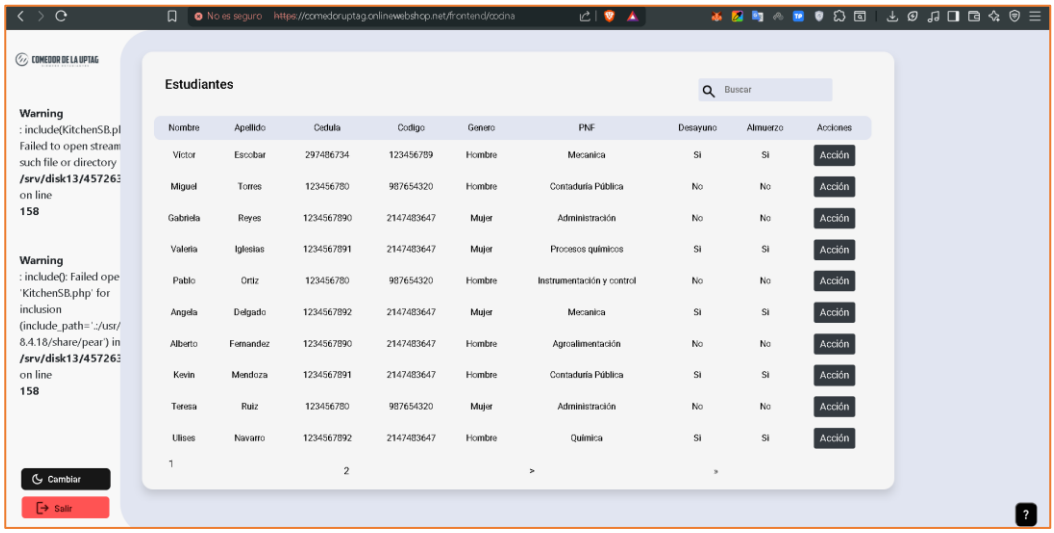
Categoría: OWASP: A10:2025 - Mal manejo de condiciones excepcionales.

Modulo: Cocina.

Descripción: Se ha identificado un fallo crítico de disponibilidad y seguridad en el módulo de "Cocina". El sistema presenta una inconsistencia de nomenclatura (Case Sensitivity) al llamar archivos .php (ej. KitchenSB.php), lo que impide la carga del módulo en el servidor de producción. Simultáneamente, el sistema expone mensajes de error detallados que revelan rutas físicas internas del servidor (ej. /usr/local/php... y /www/comedoruptag.onlinewebshop.net/...), proporcionando información sensible sobre la infraestructura del backend.

Causa: Gestión deficiente de la sensibilidad a mayúsculas en el código fuente y falta de configuración de supresión de errores en el entorno de producción. El servidor web lanza excepciones de tipo include(): Failed opening... que son visibles para el usuario final en lugar de ser capturadas por una página de error genérica. El usuario queda inhabilitado para navegar o realizar gestiones de seguridad (cambio de claves/preguntas), lo que representa una Denegación de Servicio (DoS) lógica.

Recomendaciones: Estandarizar la nomenclatura de archivos en minúsculas en todo el proyecto y corregir las referencias en el código. Es imperativo deshabilitar la visualización de errores de PHP en producción (display_errors = Off) y configurar un manejador de excepciones que redirija a páginas de error personalizadas para evitar la fuga de información técnica.



RUPTURA DE ENRUTAMIENTO Y OMISIÓN DE RECURSOS EN EL MÓDULO OPERADOR ENCARGADO DE LA GESTIÓN ESTUDIANTIL (ERROR HTTP 404)

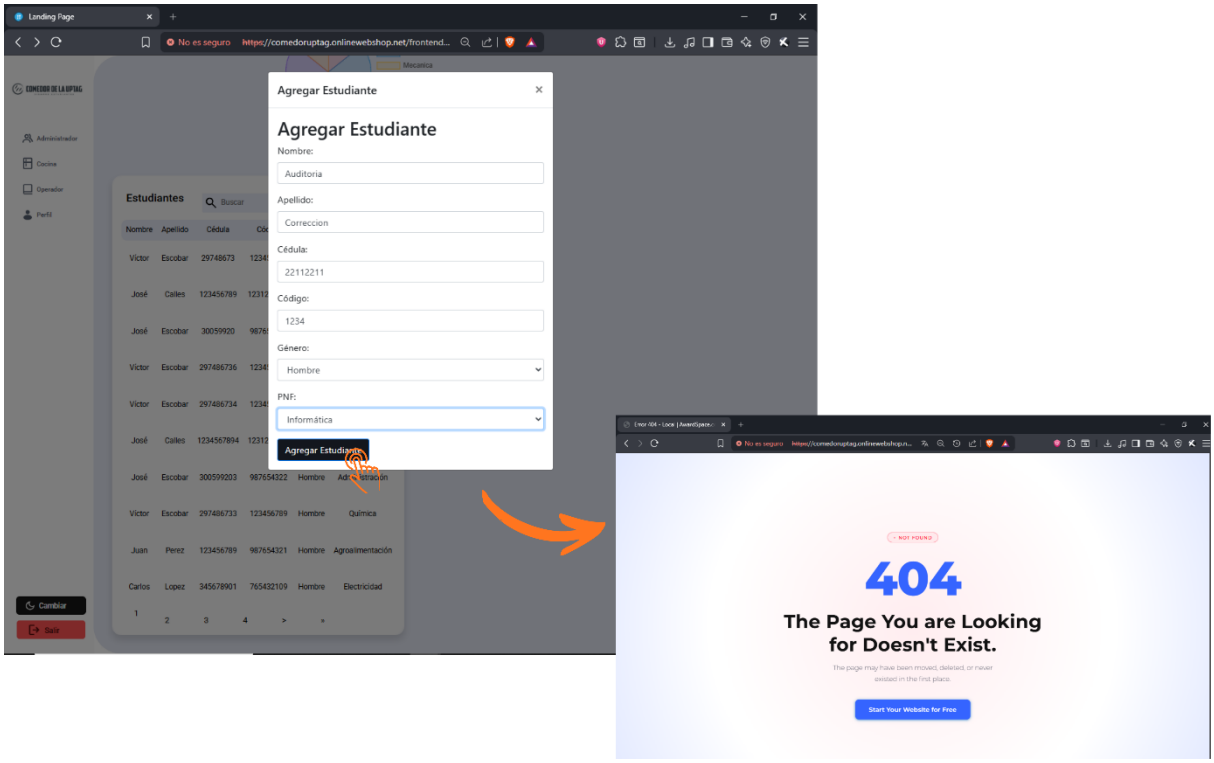
Riesgo: Alto / 7.1

OWASP: A10:2025 - Mal manejo de condiciones excepcionales / Fallo de Disponibilidad Operativa.

Descripción: Durante la evaluación dinámica del flujo de registro y modificación de estudiantes, se identificó una interrupción crítica en la capa de comunicación cliente-servidor. Al ejecutar el envío del formulario con los datos operativos, el sistema no logra procesar la petición y retorna un código de estado HTTP 404 (Not Found). En lugar de gestionar el error, la aplicación redirige a una página de error genérica expuesta directamente por el proveedor de alojamiento web. Esta falla interrumpe la funcionalidad central y objetivo específico del sistema, imposibilitando la alimentación de la base de datos e inhabilitando operativamente a los roles de Operador y Administrador, lo que se traduce en una falla total de disponibilidad para el módulo de censo estudiantil.

Causa: Deficiencias severas en el proceso de migración y despliegue a producción. La falla se origina por referencias "rotas" (Broken Links) en la estructura del código HTML/PHP, probablemente debido al uso de rutas absolutas codificadas estáticamente (Hardcoded) en el atributo action del formulario que apuntan al entorno de desarrollo local (XAMPP). Alternativamente, evidencia la omisión física del script del controlador (backend) encargado de procesar las sentencias SQL durante la carga de archivos al servidor web.

Recomendaciones: Inspeccionar exhaustivamente el código fuente de las vistas del módulo de gestión para sustituir cualquier ruta absoluta por rutas relativas dinámicas en el llamado a los endpoints. Simultáneamente, verificar el árbol de directorios en el servidor de producción para asegurar que todos los archivos lógicos encargados del procesamiento de datos (scripts PHP) hayan sido desplegados correctamente.


Agregar Estudiante
Nombre:
Auditoria
Apellido:
Correccion
Cédula:
22112211
Código:
1234
Género:
Hombre
PNF:
Informática
Agregar Estudiante
404
The Page You are Looking for Doesn't Exist.
Start Your Website for Free



HALLAZGOS DE SEVERIDAD MEDIA

REGISTRO DE USUARIOS ABIERTO Y EXCESO DE PRIVILEGIOS

Riesgo: Medio / 6.9

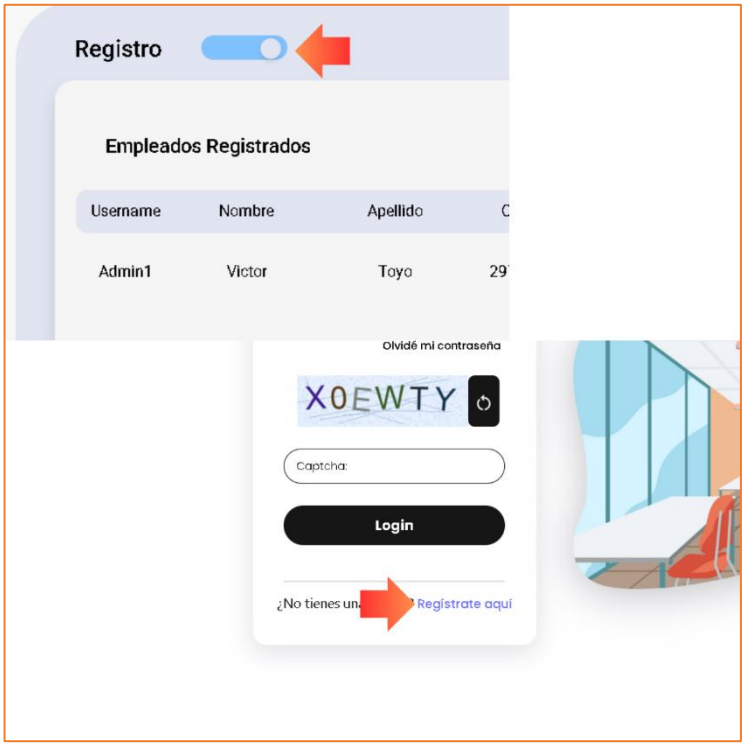
Categoría: OWASP: A07:2025 - Fallos de autenticación - ISO 27001 (A.5.1.1, A.5.1.2)

Modulo: Registro de Usuarios.

Descripción: El formulario de inicio de sesión incluye un mecanismo (checkbox) que habilita el módulo de registro de nuevos usuarios de forma persistente e indefinida. Al no existir un cierre automático de esta función ni un flujo de aprobación, cualquier actor externo puede crear credenciales de acceso al sistema.

Causa: Ausencia de controles automatizados para la gestión de estados temporales y falta de un proceso formal de validación de identidad por parte de un administrador antes de la activación de cuentas.

Recomendaciones: Implementar un temporizador (timeout) que desactive automáticamente la opción de registro tras 15 minutos de inactividad. Adicionalmente, se debe establecer un flujo de aprobación obligatoria, donde el administrador deba validar y activar manualmente cada nuevo registro antes de que el usuario pueda interactuar con el sistema.



DEFICIENCIAS EN LA EXPERIENCIA DE USUARIO (UX) Y FALTA DE ADAPTABILIDAD

Riesgo: Medio / 6.9

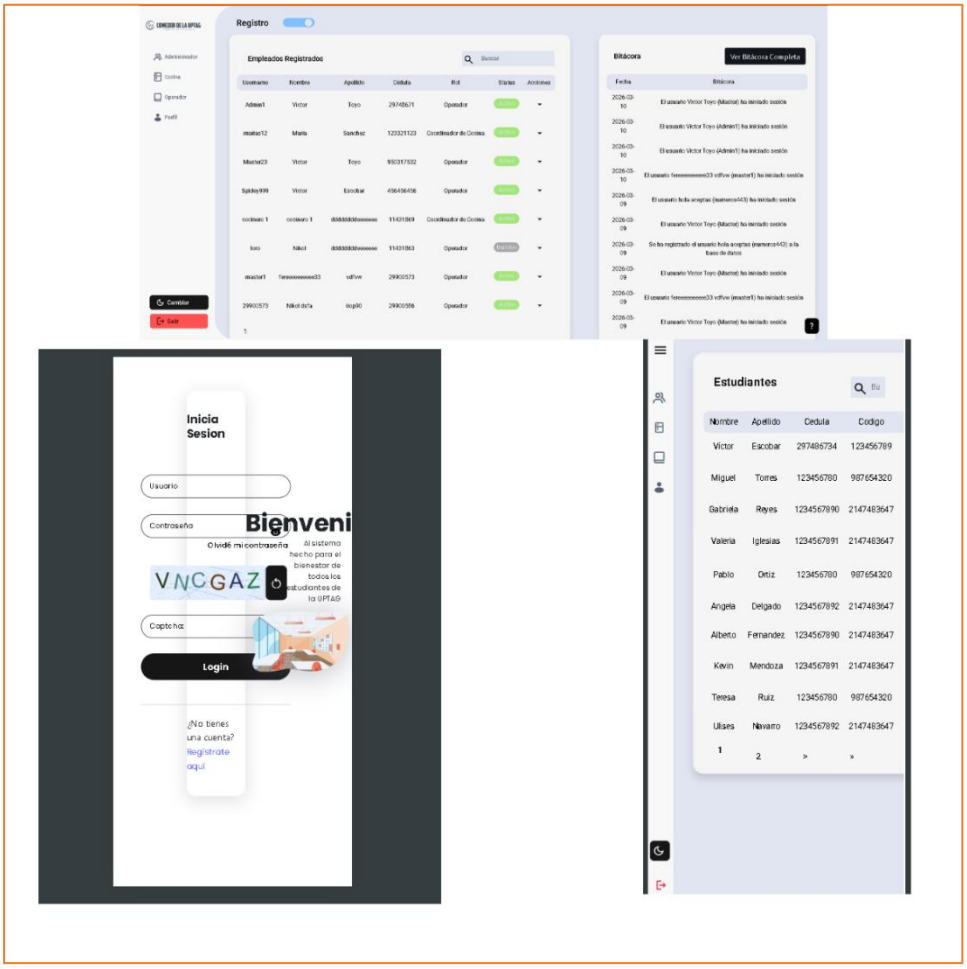
Categoría: Deficiencias Operacionales y de Mantenimiento - ISO 27001 A.8.2.1

Modulo: Interfaz de Usuario

Descripción: La interfaz del sistema presenta un diseño con baja intuitividad y carece de una arquitectura responsive. Esto impide la visualización y operación correcta en dispositivos móviles o tablets, limitando el acceso al personal en diferentes escenarios operativos.

Causa: Priorización de la funcionalidad técnica sobre la usabilidad y la ausencia de pruebas de adaptabilidad durante la fase de desarrollo.

Recomendaciones: Realizar una reingeniería del frontend bajo estándares de diseño responsivo y optimizar la paleta de colores y el layout para mejorar la eficiencia operativa y la experiencia del usuario.



FALLO LÓGICO DE VALIDACIÓN DE CREDENCIALES EN LA ACTUALIZACIÓN DEL PERFIL DE USUARIO

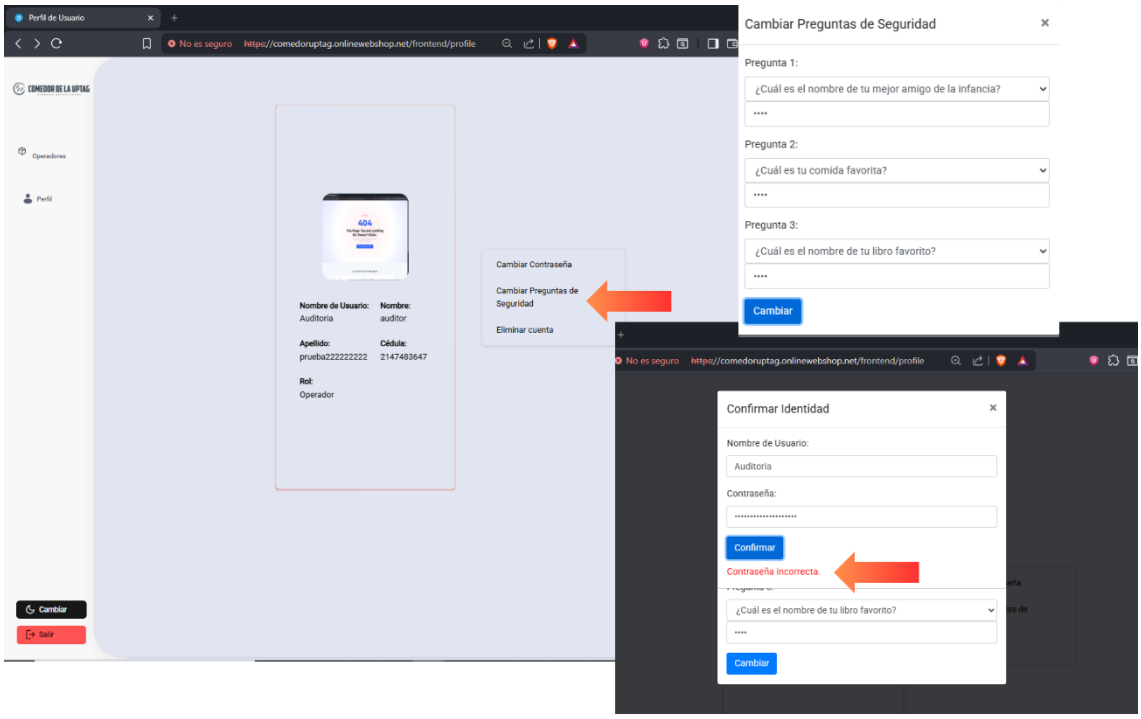
Riesgo: Medio / 6.5

OWASP: A07:2025 - Fallos de autenticación

Descripción: Durante la verificación dinámica del módulo de "Perfil", se identificó una disfunción operativa crítica que afecta la gestión de la identidad y los mecanismos de recuperación de cuentas. Ningún perfil del sistema, independientemente de su nivel de privilegios (Administrador, Operador o Cocina), posee la capacidad efectiva de modificar sus preguntas y respuestas de seguridad post-registro. Al intentar ejecutar dicha actualización, el sistema interrumpe la transacción y retorna de manera persistente un mensaje de error por "Contraseña incorrecta", aun cuando el usuario ingresa la credencial legítima que utilizó para iniciar sesión. Esta anomalía lógica imposibilita permanentemente la rotación del mecanismo de recuperación de la cuenta, dejando a la institución sin vías de mitigación en caso de que las respuestas de seguridad de un operador sean comprometidas por ingeniería social o simplemente sean olvidadas.

Causa: Deficiencia estructural en la capa lógica del backend (controlador PHP) al momento de re-autenticar al usuario para autorizar cambios sensibles. La falla sugiere una divergencia en el método de validación criptográfica empleado en este formulario específico en comparación con el del Login principal; es decir, el sistema podría estar comparando la contraseña en texto plano contra el hash almacenado en la tabla usuarios, o bien, experimenta un error de persistencia de sesión perdiendo la referencia cruzada del ID del usuario activo al realizar la consulta en la base de datos.

Recomendaciones: Inspeccionar y depurar el bloque de código del controlador encargado de procesar la actualización del perfil. Es imperativo homologar el proceso de verificación utilizando funciones criptográficas estándar (como password_verify() en el entorno PHP) para contrastar correctamente el input de seguridad proporcionado en el formulario con el hash persistente en la base de datos de la sesión actual.


Perfil de Usuario
No es seguro
https://comedoruptag.onlinewebshop.net/frontend/profile
Operadores
Perfil
Nombre de Usuario:
Auditoria
Nombre:
auditor
Apellido:
prueba222222222
Cédula:
2147483647
Rol:
Operador
Cambiar
Salir
Cambiar Contraseña
Cambiar Preguntas de Seguridad
Eliminar cuenta
Cambiar Preguntas de Seguridad
Pregunta 1:
¿Cuál es el nombre de tu mejor amigo de la infancia?
Pregunta 2:
¿Cuál es tu comida favorita?
Pregunta 3:
¿Cuál es el nombre de tu libro favorito?
Cambiar
Confirmar Identidad
Nombre de Usuario:
Auditoria
Contraseña:
Confirmar
Contraseña incorrecta.
¿Cuál es el nombre de tu libro favorito?
Cambiar

INCONSISTENCIA ARQUITECTÓNICA Y OMISIÓN DOCUMENTAL EN CONTROLES DE ACCESO (TABLA NO DECLARADA)

Riesgo: Medio / 6.3

OWASP: A06:2025 - Diseño inseguro / ISO 27001 (A.12.1.1 Procedimientos de operación documentados)

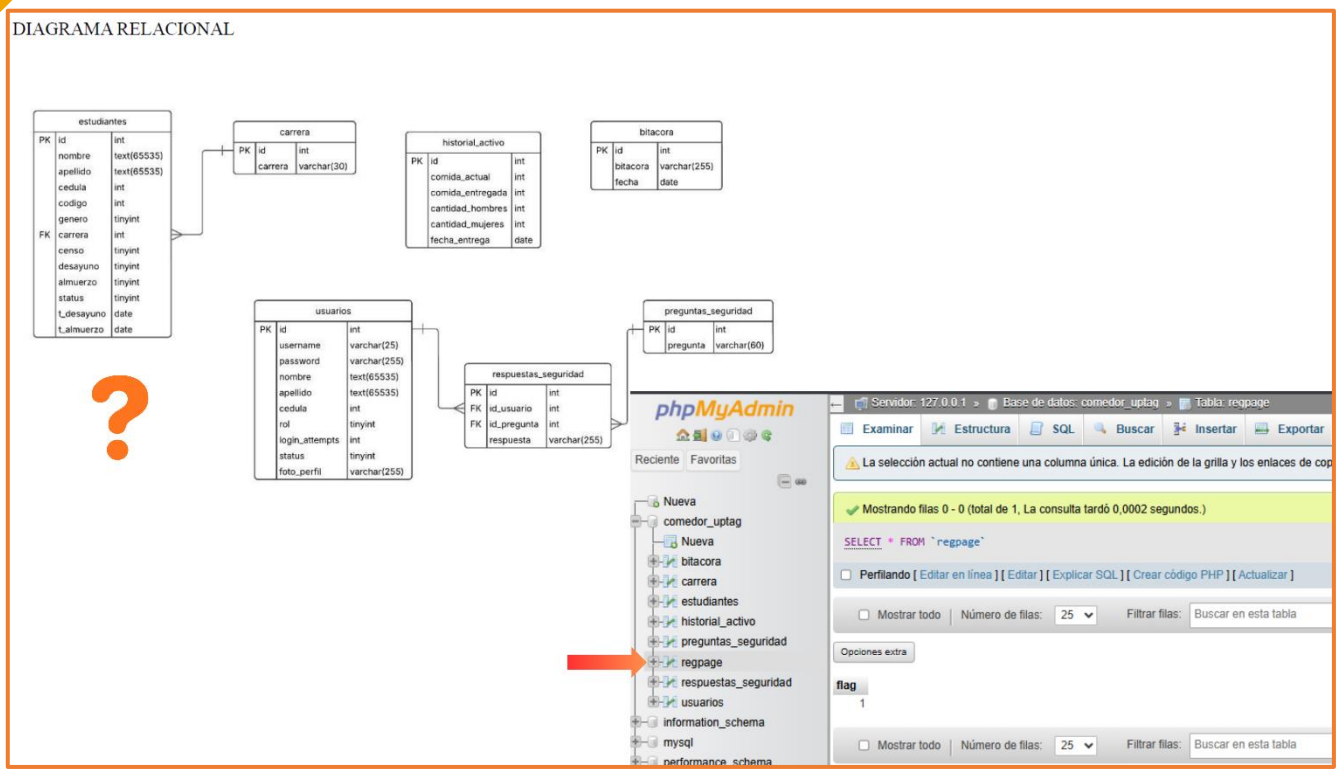
Descripción: La revisión comparativa entre la documentación técnica (Diagramas Entidad-Relación y Relacional del Manual de Sistema) y el esquema físico de la base de datos en producción, evidencia una discrepancia estructural significativa. Se constató que el entorno de producción cuenta con una tabla denominada “regpage”, la cual almacena un único atributo de tipo tinyint(1) llamado flag. Sin embargo, esta entidad no se encuentra documentada en los entregables oficiales del proyecto.

Con base en su estructura y su vinculación con el panel administrativo, se determina que esta tabla opera como un mecanismo de control de estado (interruptor lógico). Su función es gestionar los privilegios de acceso al sistema, permitiendo habilitar o bloquear la creación de nuevos usuarios. La falta de documentación sobre componentes que regulan directamente la seguridad y el control de acceso genera una severa opacidad en la arquitectura. Esta deficiencia compromete la mantenibilidad del software, dificulta la trazabilidad de los procesos y representa un obstáculo técnico para futuras auditorías o escalabilidad del sistema.

Causa: Ruptura evidente en el control de cambios y falta de sincronización durante el ciclo de vida del desarrollo de software (SDLC). El equipo de desarrollo implementó modificaciones estructurales en caliente sobre el motor de base de datos para habilitar una funcionalidad específica (el control de registros de usuarios), pero falló en reflejar dicha actualización en la arquitectura de la base de datos, dejando los diagramas de los entregables técnicos obsoletos.

Recomendaciones: Reestructurar de forma inmediata los Diagramas Entidad-Relación y Relacionales del Manual de Sistema para incorporar la entidad “regpage”. Se debe documentar formalmente su diccionario de datos (atributo flag, tipo de dato, entre otros) y detallar su propósito vinculante dentro de la lógica de negocio del control de acceso.

DIAGRAMA RELACIONAL



AUSENCIA DE CABECERAS DE SEGURIDAD HTTP (SECURITY HEADERS) EN EL SERVIDOR WEB.

Riesgo: Medio / 6.3

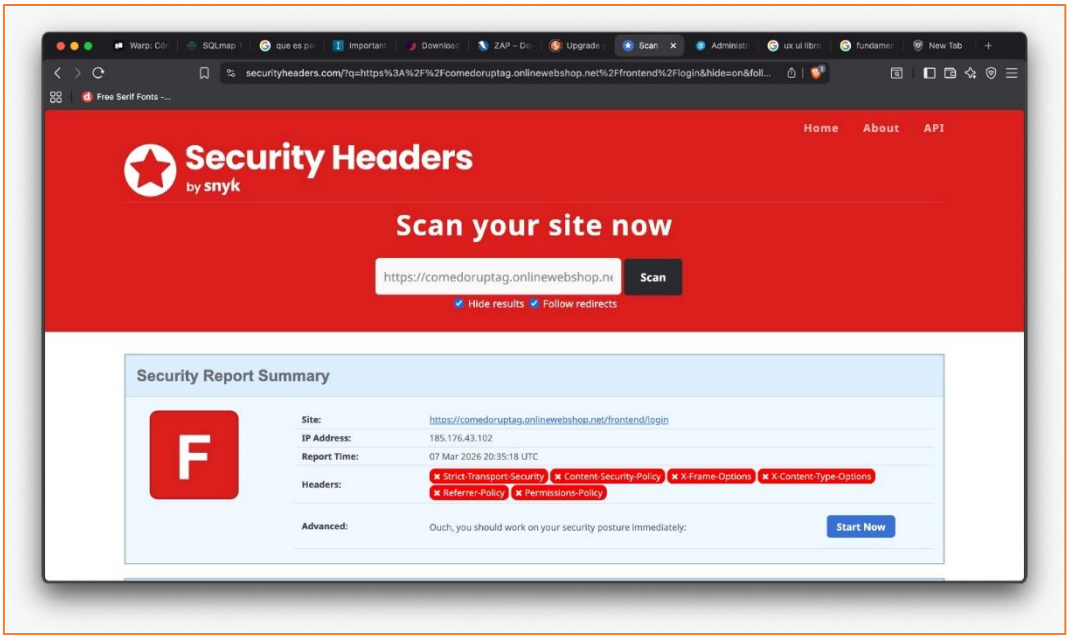
Categoria: OWASP: A05:2021 - Configuración de Seguridad Incorrecta

Descripción: Mediante el análisis de las respuestas del servidor (SecurityHeaders.com), se confirmó la ausencia total de cabeceras de seguridad esenciales. El sistema no implementa políticas que instruyan al navegador sobre cómo manejar el contenido y las conexiones, careciendo de protecciones contra ataques de Clickjacking, Cross-Site Scripting (XSS) y carga de recursos no autorizados. Las cabeceras omitidas incluyen: X-Frame-Options, Content-Security-Policy, Strict-Transport-Security, entre otras.

Causa: El servidor web y la aplicación no han sido configurados para emitir políticas de seguridad en las respuestas HTTP. Esta omisión de "Hardening" se debe a una configuración por defecto del servidor que prioriza la funcionalidad sobre la seguridad, dejando la protección de la comunicación enteramente del lado del cliente sin directrices del servidor.

Recomendaciones: Se recomienda configurar el servidor para incluir las siguientes cabeceras en cada respuesta:

- X-Frame-Options (DENY/SAMEORIGIN): Para prevenir ataques de Clickjacking.
- Content-Security-Policy (CSP): Para restringir las fuentes de scripts y estilos, mitigando ataques XSS.
- Strict-Transport-Security (HSTS): Para forzar conexiones HTTPS seguras.
- X-Content-Type-Options (nosniff): Para evitar que el navegador interprete archivos CSV o de texto como scripts ejecutables.


securityheaders.com/?q=https%3A%2F%2Fcomedoruptag.onlinewebshop.net%2Ffrontend%2Flogin&hide=on&foll...
Home
About
API
Security Headers
by snyk
Scan your site now
https://comedoruptag.onlinewebshop.ne
Scan
Hide results
Follow redirects
Security Report Summary
F
Site:
https://comedoruptag.onlinewebshop.net/frontend/login
IP Address:
185.176.43.102
Report Time:
07 Mar 2026 20:35:18 UTC
Headers:
Strict-Transport-Security
Content-Security-Policy
X-Frame-Options
X-Content-Type-Options
Referrer-Policy
Permissions-Policy
Advanced:
Ouch, you should work on your security posture immediately:
Start Now

DEFICIENCIAS EN EL ENRUTAMIENTO DE NAVEGACIÓN Y PERSISTENCIA DE ENLACES ROTOS.

Riesgo: Medio / 5.1

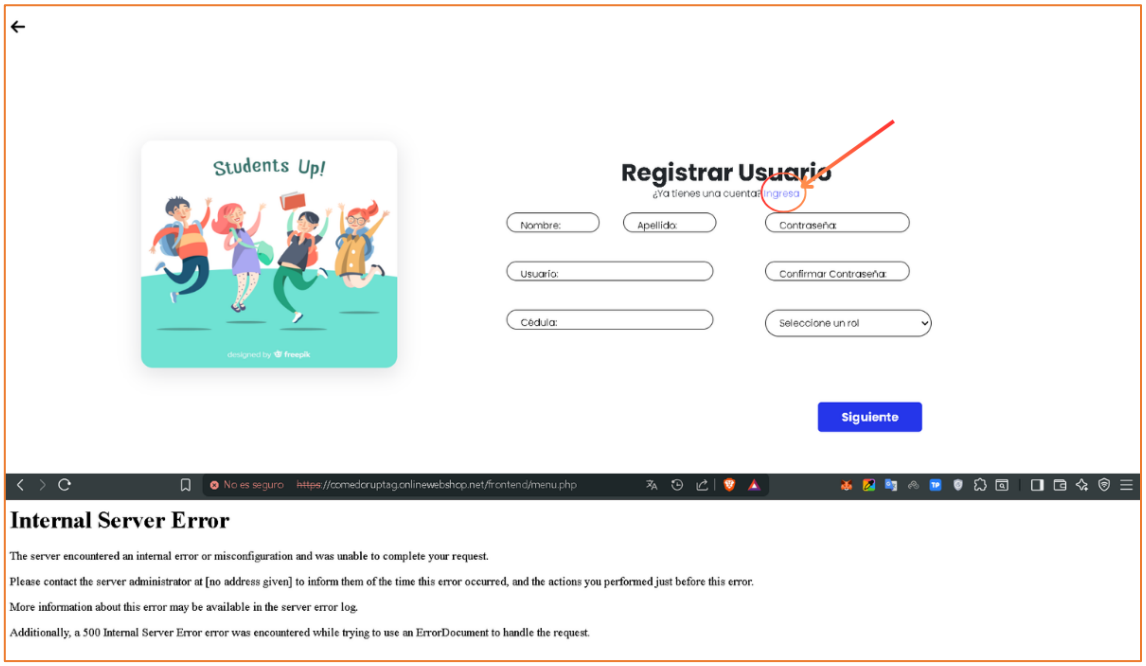
Categoría: OWASP: A01:2025 - Control de acceso roto

Modulo: Interfaz de Usuario.

Descripción: Se ha identificado una falta de integridad en la arquitectura de enlaces del sistema.

Causa: Se ha detectado una configuración errónea en el manejo de peticiones que deriva en un Error 500 (Internal Server Error) al intentar acceder a rutas inexistentes o mal referenciadas en el frontend. Esta falla indica una gestión deficiente de excepciones en el servidor y la falta de un archivo de configuración (.htaccess) que procese correctamente las redirecciones, exponiendo la inestabilidad de la infraestructura ante rutas de navegación inválidas.

Recomendaciones: Para optimizar la navegación y estabilidad del sistema, se recomienda la implementación de rutas absolutas mediante una constante global que evite errores de profundidad en los directorios, complementada con una auditoría técnica de enlaces que garantice la existencia física de cada recurso solicitado. Asimismo, es fundamental configurar páginas de error personalizadas a través del archivo .htaccess para gestionar fallos 404 de manera controlada, mejorando la experiencia del usuario y manteniendo la seguridad del entorno al evitar errores genéricos del servidor.



GESTIÓN INADECUADA DE LA FINALIZACIÓN DE SESIÓN Y REDIRECCIÓN ANÓMALA.

Riesgo: Medio / 5.1

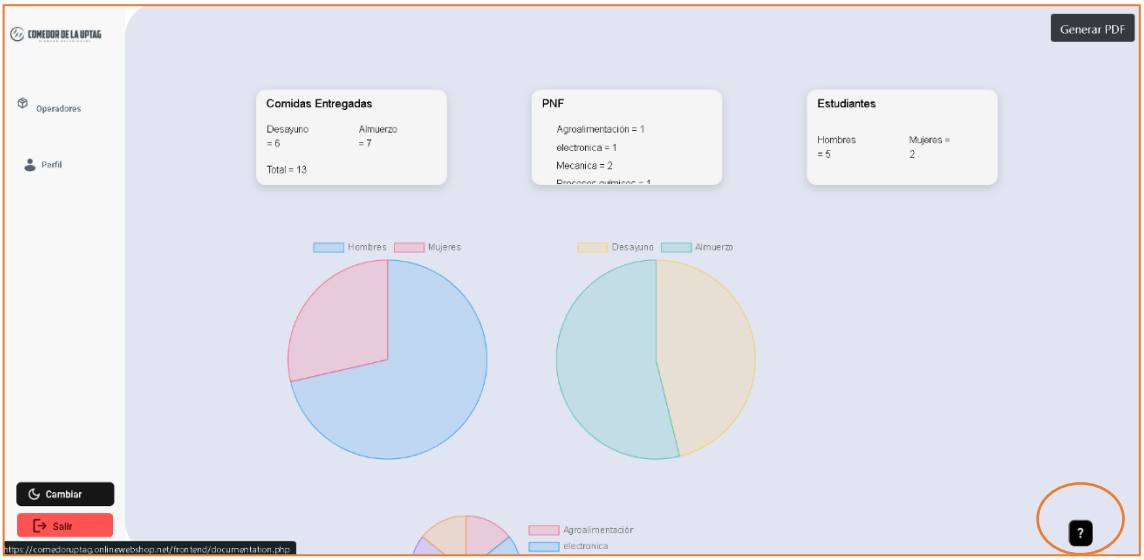
Categoría: OWASP: A07:2025 - Fallos de autenticación

Modulo: Autenticación de usuarios.

Descripción: La gestión deficiente del cierre de sesión permite que el botón de "Ayuda" redirija al login sin destruir tokens ni variables globales. Esto vulnera el principio de sesión segura, facilitando el secuestro de sesión en dispositivos de uso compartido.

Causa: El botón de "Ayuda" presenta un comportamiento inconsistente con las directrices de seguridad web. Al activarse, redirige al usuario a la interfaz de Login sin ejecutar la destrucción de los tokens de sesión o variables globales (session_destroy). El sistema viola el principio de Cierre de Sesión Seguro, lo que aumenta el riesgo de secuestro de sesión (Session Hijacking) en computadoras de uso compartido, como las del comedor.

Recomendaciones: Para fortalecer la seguridad y el flujo de navegación, se recomienda el uso de rutas absolutas que aseguren el redireccionamiento preciso de cada función, junto con la creación de un controlador de cierre de sesión que ejecute obligatoriamente session_unset() y session_destroy() para limpiar las cookies del cliente. Complementariamente, es vital implementar la invalidación de caché mediante cabeceras HTTP en el backend, evitando que el navegador almacene páginas sensibles y asegurando que el botón "Atrás" no exponga información del panel administrativo una vez finalizada la sesión.



AUSENCIA DE CREDENCIALES DE INICIALIZACIÓN Y DEFICIENCIAS EN LA DOCUMENTACIÓN PROCEDIMENTAL.

Riesgo: MEDIO / 5.1

OWASP: A02:2025 - Mala configuración de seguridad / ISO 27001 (A.12.1.1 Procedimientos de operación documentados)

Descripción: La auditoría de la documentación técnica revela omisiones críticas en el Manual de Usuario que comprometen el despliegue y la adopción segura del sistema. Primordialmente, el documento carece de la provisión de las credenciales de acceso inicial para el único rol ya autoimpuesto de Administrador ("Master"). Dado que la arquitectura del sistema delega el control de registros, la gestión de usuarios y el control de accesos exclusivamente a este rol, la omisión técnica genera un bloqueo operativo total (Denegación de Servicio a nivel administrativo) desde el momento de la entrega del software.

Adicionalmente, el documento presenta un nivel de abstracción funcional excesivo. Aunque enumera los roles de usuario (Operador, Cocina, Administrador) y las características generales del sistema, carece de especificidad procedimental. No se detallan los flujos de trabajo técnicos paso a paso, el manejo de excepciones, ni las directrices operativas necesarias para la gestión diaria, actuando únicamente como un resumen conceptual en lugar de un manual operativo estándar.

Causa: Deficiencias severas en el ciclo de vida de desarrollo de software (SDLC), específicamente en la fase de "Handover" (traspaso a producción) y en la adopción de estándares de documentación técnica. No se estableció un protocolo seguro para la transmisión de credenciales de alto privilegio, ni se implementó un enfoque de Procedimientos Operativos Estándar (SOP) al redactar la guía del usuario final.

Recomendaciones: Aprovisionamiento Seguro de Credenciales: Suministrar de manera inmediata, a través de un canal de comunicación cifrado e independiente del manual público, las credenciales de acceso administrativo ("Master"). A nivel de código, el sistema debe forzar obligatoriamente el cambio de esta contraseña (política *Force Password Change on First Login*) durante el primer acceso para garantizar la no repudiación.

Reestructuración Documental (SOP)**:** Rediseñar el Manual de Usuario transformándolo en un documento de Procedimientos Operativos Estándar (SOP). Este debe incluir instrucciones de ejecución detalladas (paso a paso) para cada uno de los roles, incorporando captura de flujos completos (como, por

ejemplo, ciclo de vida del registro y censo de un estudiante), códigos de error comunes y directrices de seguridad para los operadores





ANÁLISIS DE SEGURIDAD CON HERRAMIENTAS AUTOMATIZADAS

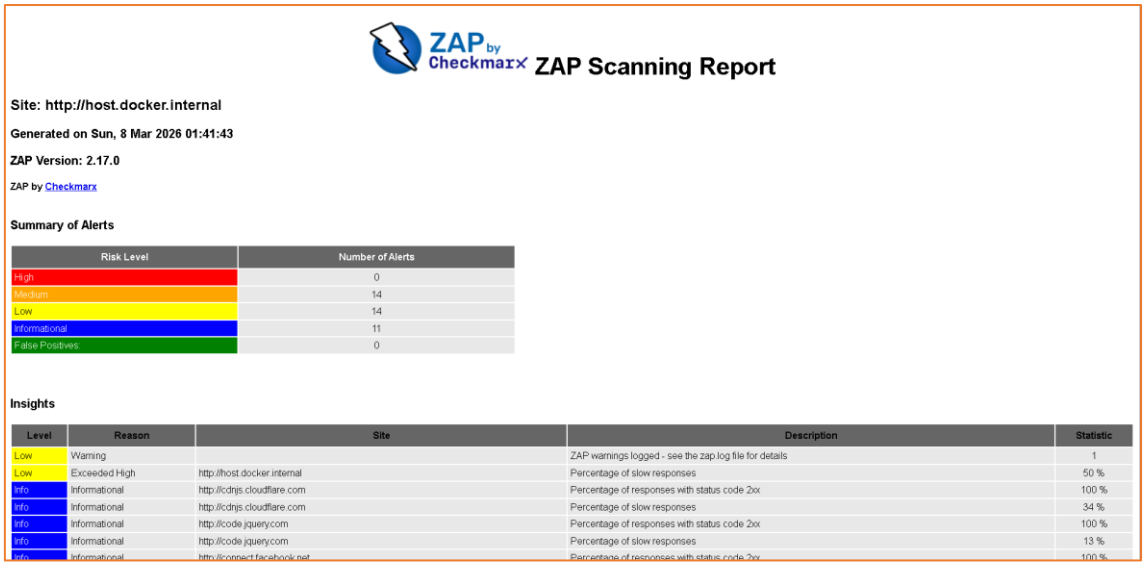
ANÁLISIS DE SEGURIDAD CON HERRAMIENTAS AUTOMATIZADAS

En esta fase se utilizaron herramientas de software especializado para detectar vulnerabilidades que no son fácilmente identificables mediante revisión manual. Se aplicaron dos enfoques complementarios: SAST (Análisis de Código Fuente) y DAST (Análisis en Tiempo de Ejecución).

ANÁLISIS DINÁMICO DE APLICACIONES (DAST) - OWASP ZAP

Esta prueba se realizó mediante un escaneo activo sobre la URL del sistema para identificar fallos de configuración y vulnerabilidades de red.

ID	Vulnerabilidad Detectada	Riesgo	Descripción Técnica	Recomendación
Z01	**Ausencia de Tokens Anti-CSRF**	**Medio**	Los formularios no protegen contra peticiones maliciosas forzadas desde sitios externos.	Implementar tokens únicos por sesión en cada formulario de envío.
Z02	**Falta de Cabecera X-Content-Type**	**Bajo**	El servidor no impide que el navegador interprete archivos de forma incorrecta (MIME Sniffing).	Configurar X-Content-Type-Options: nosniff en el archivo .htaccess.
Z03	**Divulgación de Banner del Servidor**	**Bajo**	Las cabeceras HTTP exponen versiones exactas de Apache/PHP, facilitando ataques dirigidos.	Ocultar la firma del servidor en la configuración global de Apache.



ZAP by Checkmarx ZAP Scanning Report

Site: http://host.docker.internal

Generated on Sun, 8 Mar 2026 01:41:43

ZAP Version: 2.17.0

ZAP by Checkmarx

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	14
Low	14
Informational	11
False Positives:	0

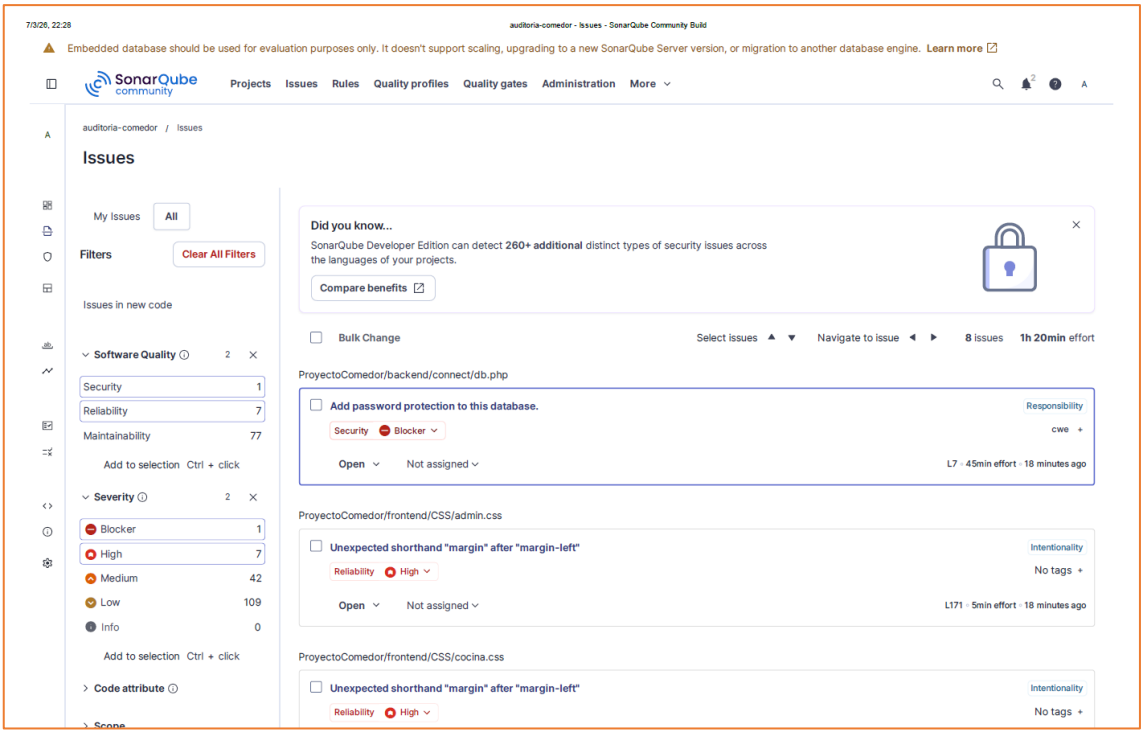
Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap.log file for details	1
Low	Exceeded High	http://host.docker.internal	Percentage of slow responses	50 %
Info	Informational	http://cdnjs.cloudflare.com	Percentage of responses with status code 2xx	100 %
Info	Informational	http://cdnjs.cloudflare.com	Percentage of slow responses	34 %
Info	Informational	http://code.jquery.com	Percentage of responses with status code 2xx	100 %
Info	Informational	http://code.jquery.com	Percentage of slow responses	13 %
Info	Informational	http://connect.facebook.net	Percentage of responses with status code 2xx	100 %

ANÁLISIS ESTÁTICO DE SEGURIDAD (SAST) – SONARQUBE

Se analizó el código fuente para evaluar la calidad del software y detectar patrones de programación que vulneran la ISO 27001.

ID	Hallazgo de Código	Gravedad	Impacto Operativo	Recomendación
S01	**Vulnerabilidades de Inyección SQL**	**Crítica**	Concatenación directa de variables en consultas, permitiendo el robo de la base de datos.	Migrar todas las consultas a **Sentencias Preparadas (PDO)**.
S02	**Criptografía Débil (MD5/SHA1)**	**Alta**	Uso de algoritmos obsoletos para el hash de contraseñas, fáciles de descifrar por fuerza bruta.	Utilizar la función password_hash() con el algoritmo **Bcrypt** o **Argon2**.
S03	**Code Smells y Código Muerto**	**Media**	Presencia de variables no inicializadas y funciones huérfanas que dificultan el mantenimiento.	Depurar el código eliminando lógica redundante para reducir la deuda técnica.





INSPECCION DE CODIGO

ARQUITECTURA DE SOFTWARE DESORDENADA Y BAJA ESCALABILIDAD

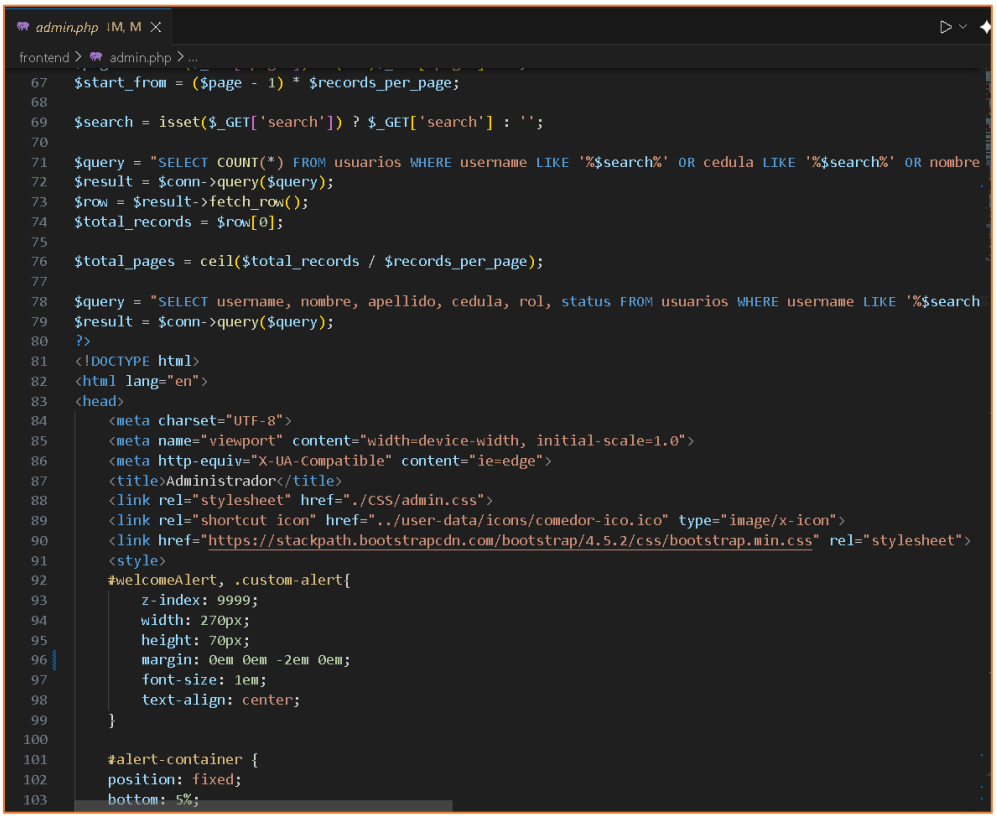
Riesgo: Medio / 4.6

Categoría: ISO 27001 (A.8.25 - Codificación Segura) / Deuda Técnica.

Descripción: Se ha identificado que el código fuente carece de una estructura modular definida (como MVC o capas), presentando una mezcla de lógica de negocio, acceso a datos y diseño en los mismos archivos. Esta organización "espagueti" dificulta la implementación de nuevas funcionalidades.

Causa: Ausencia de un patrón de diseño arquitectónico desde la fase de planificación y priorización de la entrega inmediata sobre la calidad del código.

Recomendación: Iniciar un proceso de refactorización hacia un patrón arquitectónico (ej. Modelo-Vista-Controlador) y separar las responsabilidades del código para facilitar el crecimiento del sistema.



DOCUMENTACIÓN TÉCNICA INSUFICIENTE Y OMISIÓN DE COMENTARIOS EN FUNCIONES CRÍTICAS

Riesgo: Medio / 4.6

Categoría: ISO 27001 (A.5.37 - Documentación de Operaciones).

Descripción: Tras la revisión se determinó que la documentación interna es deficiente y discontinua. Si bien existen secciones comentadas, numerosas funciones complejas y bloques de lógica de negocio carecen de descripciones técnicas, parámetros de entrada/salida o explicaciones de su propósito.

Causa: Inexistencia de un estándar de codificación obligatoria que exija la documentación de cada componente desarrollado y falta de supervisión en la fase de construcción.

Recomendación: Establecer una política de documentación obligatoria utilizando estándares industriales (como **PHPDoc**). Se debe realizar una jornada de "Refactorización de Documentación" para asegurar que todas las funciones, especialmente las de autenticación y manejo de base de datos, cuenten con comentarios que describan su comportamiento y dependencias.

checkcurrentpassword.php M

backend > users > checkcurrentpassword.php > ...

```php
<?php
include '../connect/db.php';

header('Content-Type: application/json');

if ($_SERVER["REQUEST_METHOD"] == "POST") {
    $user_id = trim($_POST['user_id']);
    $new_password = trim($_POST['new_password']);

    $new_password_hash = hash('sha256', $new_password);

    $query = "SELECT password FROM usuarios WHERE id = ?";
    $stmt = $conn->prepare($query);
    $stmt->bind_param("i", $user_id);
    $stmt->execute();
    $result = $stmt->get_result();

    if ($result->num_rows > 0) {
        $user = $result->fetch_assoc();
        $current_password_hash = $user['password'];

        if ($new_password_hash === $current_password_hash) {
            echo json_encode(['success' => false, 'message' => 'La nueva contraseña no puede ser la misma qu
        } else {
            echo json_encode(['success' => true]);
        }
    } else {
        echo json_encode(['success' => false, 'message' => 'Usuario no encontrado.']);
    }

    $stmt->close();
} else {
    echo json_encode(['success' => false, 'message' => 'Método de solicitud no válido.']);
}

$conn->close();
```

DEFICIENCIA EN LA TRAZABILIDAD Y GESTIÓN DEL CONTROL DE VERSIONES

Riesgo: Medio / 6.8

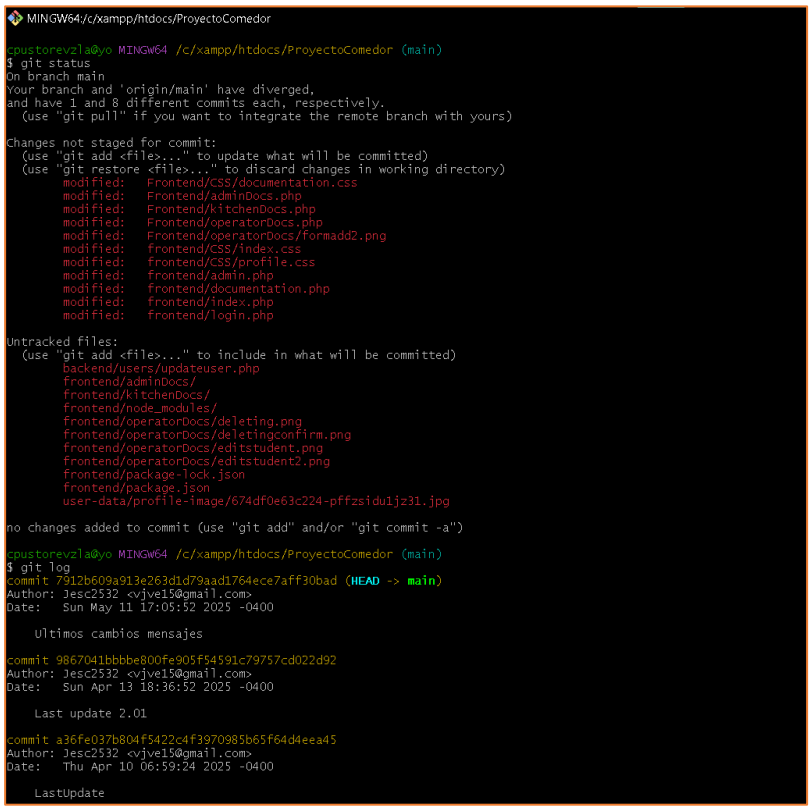
Categoría: ISO 27001 (A.6.1.4 - Control de Cambios).

Descripción: Aunque el proyecto utiliza Git, se detectaron múltiples cambios en el entorno local que no han sido registrados (*commiteados*). Además, los mensajes de los commits existentes son genéricos (ej. "v2", "cambios") y carecen de contexto sobre las modificaciones realizadas.

Causa: Inexistencia de un flujo de trabajo de Git (como GitFlow) y descuido en la frecuencia de sincronización entre el entorno de desarrollo y el repositorio principal.

Impacto: Pérdida de trazabilidad histórica. Ante una falla crítica, es imposible identificar quién realizó un cambio específico o por qué se hizo, además del riesgo de pérdida de código por cambios no respaldados en el repositorio.

Recomendación: Establecer un estándar de mensajes descriptivos (ej. Conventional Commits) y obligar a que cada sesión de desarrollo finalice con la carga de los cambios realizados al repositorio central.





PRUEBA DE RENDIMIENTO

OPTIMIZACIÓN DE INTERFAZ EN RANGO DE ESTABILIDAD (PERFORMANCE 81/100)

Riesgo: Bajo / 2.3

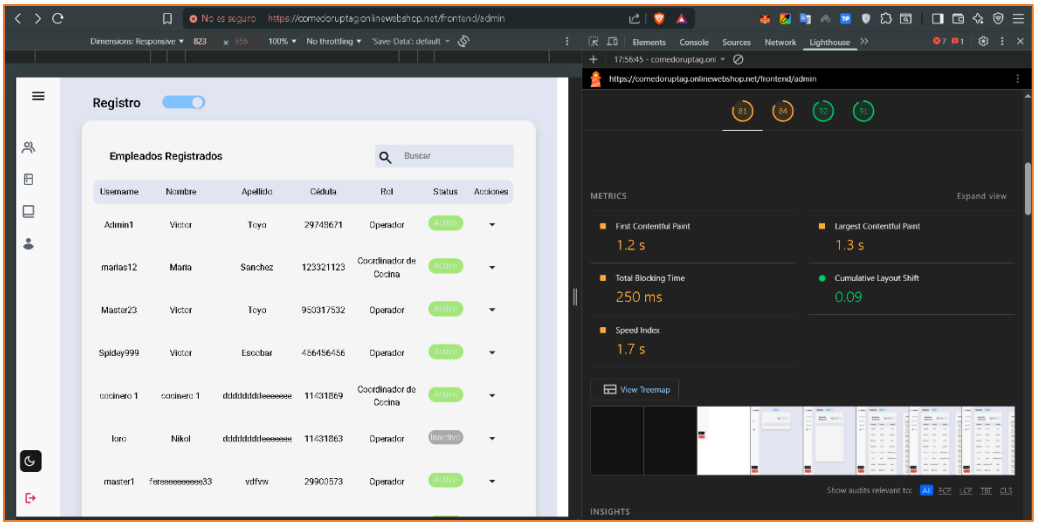
Categoría: ISO 27001 (A.8.25 - Codificación Segura) y Estándares de Calidad Web (W3C).

Descripción: El sistema presenta un rendimiento robusto con una puntuación de 81/100, logrando un First Contentful Paint (FCP) de 1.2s y un Largest Contentful Paint (LCP) de 1.3s. Estos valores indican que la aplicación es rápida y funcional para el usuario final. No obstante, se mantiene en el rango naranja debido a oportunidades de mejora en el tiempo de bloqueo y la estabilidad visual (CLS).

Causa: Aunque el sistema rinde de manera óptima, persiste una ligera latencia en el Total Blocking Time (250 ms) y en el desplazamiento de elementos durante la carga (CLS: 0.09), causados por la ejecución de scripts secundarios y la falta de dimensiones reservadas para elementos visuales.

Recomendación: Para alcanzar el rango verde (90-100), se deben realizar los siguientes ajustes:

- Reducción de TBT: Fragmentar tareas largas de JavaScript para liberar el hilo principal del navegador.
- Estabilidad Visual: Definir dimensiones explícitas (width/height) en imágenes y contenedores para reducir el Cumulative Layout Shift.
- Accesibilidad: Atender las advertencias menores en el apartado de Accesibilidad (84/100) para asegurar un software inclusivo según normativas internacionales.





OBSERVACIONES FINALES

VISIÓN GENERAL DE LA AUDITORÍA

Seguridad y Resiliencia

El sistema bajo estudio presenta un perfil de riesgo elevado debido a la identificación de vulnerabilidades críticas mediante análisis dinámico (DAST) con OWASP ZAP. Se detectaron brechas graves de Cross-Site Scripting (XSS) y una preocupante falta de sanitización en los puntos de entrada de datos, lo que permite la inyección de código malicioso y compromete la integridad de la base de datos. La ausencia de controles preventivos esenciales, tales como tokens anti-CSRF y validaciones robustas en el servidor, refleja una postura de seguridad reactiva que deja la infraestructura vulnerable ante ataques dirigidos.

Documentación Técnica y de Usuario

Aunque el proyecto dispone de manuales de usuario y de sistema que constituyen una base de conocimiento inicial, se observa una desactualización técnica significativa. La documentación actual no está alineada con las últimas funcionalidades del software ni posee un diseño organizacional que facilite la transferencia de conocimiento. Se recomienda una actualización integral bajo estándares profesionales para asegurar que la documentación sea una herramienta operativa útil y no solo un requisito formal.

Análisis del Código Fuente

Se identificó una carencia de patrones de diseño estructurales (como MVC), resultando en una lógica de "código espagueti" que eleva la deuda técnica y dificulta el mantenimiento evolutivo. Si bien existe una organización física aceptable de archivos segregados por funcionalidad (Backend, Frontend y DB), la lógica interna presenta un alto acoplamiento. Es imperativa una refactorización hacia una arquitectura modular para garantizar la cohesión del código y permitir la escalabilidad del sistema administrativo

Gestión del Control de Versiones

La auditoría confirmó una deficiencia estructural en el uso de Git. A pesar de existir un repositorio iniciado, la falta de una cultura de "commits" descriptivos y la presencia de cambios locales no sincronizados impiden una trazabilidad forense. Esto imposibilita la reversión segura ante errores críticos y limita la colaboración eficiente entre desarrolladores, contraviniendo el control A.6.1.4 de la norma ISO 27001.

Divergencia Crítica frente a los Requerimientos de la Comunidad

La acumulación de inconsistencias estructurales, fallos de disponibilidad (errores de enrutamiento) y bloqueos lógicos detectados a lo largo de la auditoría, evidencia una brecha severa entre el producto de software entregado y las necesidades operativas reales de la institución. Es observable un

incumplimiento sustancial de los requerimientos funcionales y no funcionales exigidos por la comunidad universitaria para la gestión eficiente del comedor. Esta falta de alineación entre el desarrollo técnico y el objetivo de negocio imposibilita la adopción orgánica del sistema, impidiendo que los operadores logren un uso adecuado, fluido y seguro de la plataforma en su entorno diario.

Ausencia Documental de Metodologías

La revisión exhaustiva de los artefactos entregables revela una omisión absoluta de registros vinculados a la aplicación de metodologías formales para el Ciclo de Vida del Desarrollo de Software (SDLC). No existe evidencia del uso de herramientas de gestión de tareas (Jira, Trello, Asana), ni se ha proporcionado un cronograma de actividades (como un Diagrama de Gantt) o hitos de entrega. La falta de esta documentación base imposibilita realizar una auditoría sobre el cumplimiento de los plazos de entrega y la eficiencia en la estimación de tiempos del equipo de desarrollo, sugiriendo una gestión de proyecto de naturaleza improvisada que derivó en la alta deuda técnica del producto final.

Cumplimiento Legal y Licenciamiento

A pesar del uso de recursos de terceros de libre acceso, el proyecto incurre en una omisión legal crítica al no declarar explícitamente una licencia de distribución de software (como MIT o GNU), lo que genera una ambigüedad jurídica sobre la propiedad intelectual. A nivel regulatorio, las vulnerabilidades detectadas en la protección de la base de datos (datos personales, nombres, cédulas de estudiantes y roles) representan un riesgo de incumplimiento frente a los principios de privacidad y protección de la información establecidos en la Ley Especial Contra los Delitos Informáticos (LECDI) de la República Bolivariana de Venezuela, particularmente en lo que respecta a la confidencialidad y el resguardo de la data alojada en instituciones de educación pública. Es mandatorio adecuar las políticas de seguridad del sistema para garantizar la conformidad con el marco jurídico nacional vigente.

Ayuda Contextual y Tooltips en la Interfaz de Usuario

La evaluación heurística de la interfaz de usuario reveló una omisión crítica de elementos de asistencia contextual, como etiquetas emergentes e íconos interactivos, lo que contraviene los principios fundamentales de usabilidad y accesibilidad web. Esta carencia, sumada a una documentación técnica insuficiente, eleva la carga cognitiva del personal e incrementa el riesgo de errores humanos en procesos operativos y acciones irreversibles.

Para mitigar estos riesgos, se recomienda la implementación urgente de tooltips descriptivos, validaciones de datos en tiempo real y ventanas de

confirmación para acciones críticas. Asimismo, es imperativo estandarizar las rutas de asistencia para que proporcionen guías rápidas de uso sin comprometer la persistencia de la sesión activa del operador.

Carencia Absoluta de un Entorno de Pruebas en el Desarrollo

Al auditar la estructura del código fuente, se constató la inexistencia de un marco de pruebas automatizadas por parte del equipo de desarrollo. No se evidencian scripts de Pruebas Unitarias (para validar funciones aisladas), Pruebas de Integración (para asegurar la correcta comunicación entre el frontend, el backend y la base de datos), ni protocolos documentados de Pruebas de Aceptación con el usuario final. Esta carencia metodológica de aseguramiento de calidad (QA) explica la alta presencia de enlaces rotos (Errores 404 y 500) y fallos lógicos graves que llegaron al entorno de producción sin ser detectados.

CONCLUSIONES

Tras la evaluación integral realizada al Sistema de Gestión Administrativa del Comedor de la UPTAG, se concluye que la plataforma presenta un perfil de riesgo elevado que compromete su integridad, disponibilidad y seguridad. Si bien el sistema demuestra un rendimiento web aceptable en términos de velocidad de carga, las deficiencias estructurales en el código y la configuración del servidor representan una amenaza latente para la continuidad operativa de la institución.

Los puntos clave que fundamentan esta conclusión son:

- **Vulnerabilidades Técnicas Críticas:** La presencia de credenciales administrativas por defecto y con privilegios excesivos en la base de datos, sumada a la falta de sanitización de entradas que permite ataques de inyección, expone la información sensible de la comunidad universitaria a actores malintencionados.
- **Deficiencias de Diseño y Lógica:** Se identificaron fallos de diseño graves, como la lógica de bloqueo irreversible que puede inhabilitar permanentemente al administrador del sistema, y la falta de manejo de sesiones seguras que facilita el secuestro de identidades.
- **Deuda Técnica y Mantenibilidad:** La arquitectura de "código espagueti" y la desincronización entre la base de datos física y la documentación técnica (como la tabla regpage no declarada) dificultan enormemente el mantenimiento evolutivo y la escalabilidad del software.
- **Vacíos en la Gestión Estándar:** La falta de una cultura de control de versiones con Git y la ausencia de una licencia de distribución formal generan una ambigüedad jurídica y técnica sobre la propiedad intelectual del sistema.

En síntesis, el sistema requiere una intervención técnica prioritaria orientada a la refactorización del código bajo patrones de diseño modernos y el endurecimiento (*hardening*) de las políticas de seguridad en el servidor. Sin la implementación de las medidas correctivas detalladas en este informe, la plataforma permanecerá vulnerable a interrupciones críticas del servicio y compromisos de datos de alta severidad.